

Guía Metodológica de la Encuesta INES-ENS

Cómo convertir un cuestionario en un instrumento serio de gobierno del riesgo, sin perder del todo el sentido del humor.

1. Propósito y alcance

Esta guía explica cómo aplicar la Encuesta Integral INES-ENS para evaluar el estado de la seguridad de la información, la madurez y la resiliencia digital en organizaciones sometidas (o cercanas) al Esquema Nacional de Seguridad.[web:8][web:37][web:39] El instrumento está alineado con el RD 311/2022, la obligación de evaluación periódica del estado de seguridad y el marco de métricas e indicadores recogido en las guías CCN-STIC 815 y 824.[web:20][web:33][web:38]

La encuesta puede utilizarse en administraciones públicas, entidades del sector público institucional y empresas privadas proveedoras de servicios al sector público o afectadas por ENS y NIS2.[web:35][web:21][web:24][web:27] El enfoque metodológico permite su uso tanto en autoevaluación como en ejercicios coordinados por órganos transversales (por ejemplo, una consejería, un ministerio o una unidad corporativa de ciberseguridad).

2. Principios de diseño

Se han seguido varios principios rectores:

- Alineamiento normativo: cada bloque se fundamenta en obligaciones y recomendaciones del ENS y sus guías asociadas (808, 815, 817, 824, 802), así como en el RD 311/2022 y perfiles de cumplimiento.[web:18][web:30][web:36][web:38][web:37]
- Orientación a indicadores: las preguntas están pensadas para alimentar indicadores cuantitativos y cualitativos coherentes con el marco INES, incluyendo grado de implantación, eficacia, eficiencia e impacto de incidentes.[web:8][web:20][web:33]
- Escalabilidad: la estructura admite su uso en entidades pequeñas (lectura directa) y grandes organizaciones (agregación por unidades, servicios o sistemas).
- Conversación, no interrogatorio: el tono, aunque formal, busca estimular respuestas honestas y reflexión interna, evitando la mera respuesta “para quedar bien”.

3. Estructura de la encuesta y lógica de secciones

La encuesta se divide en 11 secciones, cada una vinculada a dimensiones clave de ENS e INES:

1. Información general de la organización: variables de contexto (sector, tamaño, rol, categoría de sistemas), necesarias para segmentar resultados y ajustar expectativas.
2. Gobierno y estrategia: elementos de alto nivel previstos en ENS (política, responsabilidades, estrategia, reporting), corazón de la madurez de seguridad.[web:37][web:41]
3. Alcance, perfiles y certificación: cómo se aplica ENS en la práctica, si se han adoptado perfiles, y el grado de conformidad formal.[web:37][web:40][web:38]
4. Métricas de implantación: grado de implementación de medidas ENS, frecuencia de revisión y nivel de automatización, siguiendo CCN-STIC 815 y 824.[web:20][web:33][web:36]
5. Métricas de eficacia y eficiencia: indicadores de resultados, costes y rendimiento.[web:30][web:33]
6. Gestión de ciberincidentes: procesos, métricas e integración con CCN-CERT y NIS2, basados en CCN-STIC 817.[web:30][web:32]
7. Interconexiones y proveedores: alineado con ENS, extensión de RD 311/2022 a proveedores y espíritu NIS2 (cadena de suministro).[web:35][web:21][web:24][web:27]
8. Madurez de gestión: escala tipo CMM que permite derivar un Índice Global de Madurez (IGM).
9. Uso de INES y herramientas: captura el grado de interiorización del propio instrumento nacional.
10. Inversión y retorno: variables necesarias para análisis de ROI y para alimentar modelos actuariales básicos.
11. Visión de futuro y preguntas abiertas: espacio para riesgos emergentes (IA, post-cuántico) y propuestas propositivas.

4. Modalidades de aplicación

Se proponen tres modalidades principales:

4.1. Autoevaluación individual

La organización responde por sí misma, habitualmente a nivel corporativo o de unidad de negocio. Es apropiada para:

- Obtener una primera fotografía antes de auditorías o proyectos ENS.
- Revisar la evolución anual (especialmente en conjunción con INES).

En esta modalidad, se recomienda que el cuestionario sea cumplimentado de forma colaborativa por seguridad, TI, negocio y, cuando proceda, continuidad de negocio.

4.2. Ejercicio coordinado (multi-entidad o multi-unidad)

Un organismo coordinador (por ejemplo, una consejería o ministerio) envía la encuesta a varias entidades dependientes:

- El objetivo es obtener una visión agregada y comparativa de madurez ENS–INES.
- Posteriormente se pueden identificar perfiles de cumplimiento, necesidades de soporte y prioridades comunes.

Conviene establecer un calendario y un repositorio central (por ejemplo, una herramienta GRC o un simple repositorio de ficheros) para consolidar resultados.

4.3. Revisión externa o auditoría

Equipos de auditoría interna o externa pueden utilizar la encuesta como guion estructurado de entrevistas y revisión documental:

- No sustituye las guías de auditoría CCN-STIC 802, pero las complementa con una capa de percepción y de visión estratégica.[web:38]
- Resulta útil para contrastar “lo que dicen los documentos” con “cómo se percibe la realidad” en las áreas responsables.

5. Escalas de respuesta e interpretación

Las preguntas emplean varios tipos de escala:

- Opción múltiple categórica: permite análisis estadístico sencillo y comparaciones entre organizaciones.
- Escala ordinal (1–5) de madurez: diseñada para derivar un Índice Global de Madurez (IGM) por dominio y global.
- Preguntas abiertas: permiten capturar matices y casos singulares no reducibles a números.

5.1. Escala de madurez (1–5)

La escala propuesta se inspira en modelos CMM y es compatible con los enfoques utilizados por el CCN en guías ENS:

12. Inicial: procesos informales, dependientes de personas concretas.
13. Repetible: ciertas prácticas se repiten, aunque sin normalización completa.
14. Definido: procesos documentados, difundidos y aplicados de forma general.
15. Gestionado y medido: se establecen indicadores, objetivos y seguimiento.
16. Optimizado: se evalúa y mejora continuamente, con ajustes proactivos.

La conversión a un IGM se detalla en la plantilla de Excel, pero conceptualmente se trata de la media ponderada de las puntuaciones por dominio.

6. Frecuencia recomendada y ciclo anual ENS–INES

La metodología se alinea con el ciclo anual de evaluación exigido por ENS:

17. Realización de la encuesta al menos una vez al año, preferentemente antes de la preparación del Informe de Estado de Seguridad e INES.[web:8][web:33]
18. Consolidación y análisis de resultados a nivel de entidad u órgano coordinador.
19. Identificación de áreas de mejora y priorización de acciones para el siguiente ejercicio.
20. Actualización de la planificación (planes directores, planes de adecuación, etc.).
21. Preparación de evidencias para auditorías y para el informe INES.

En organizaciones con alta exposición al riesgo, puede ser recomendable un ciclo semestral para las secciones más dinámicas (incidentes, proveedores, IA).

7. Tratamiento de la información y confidencialidad

Los resultados de la encuesta pueden contener información sensible sobre debilidades de seguridad. Se recomienda:

- Definir claramente quién puede ver los resultados individuales.
- Anonimizar los datos en análisis agregados (por ejemplo, informar por tipos de entidad y no por nombre).
- Establecer reglas de uso: la finalidad principal es la mejora continua, no la penalización directa.

Cuando se utilice la encuesta en contextos multi-entidad coordinados por administraciones superiores, conviene firmar compromisos de confidencialidad y aclarar si habrá devoluciones de benchmarking.

8. Cómo derivar indicadores y cuadros de mando

A partir de las respuestas, pueden obtenerse múltiples indicadores. Algunos ejemplos:

- Porcentaje de entidades con política de seguridad formalmente aprobada y revisada en 12 meses.
- Distribución de categorías ENS de sistemas (Básica, Media, Alta).
- Nivel medio de madurez por dominio (riesgos, identidades, incidentes, continuidad, proveedores, métricas).
- Porcentaje de entidades que utilizan INES como herramienta de gestión interna, más allá del cumplimiento.
- Media de recursos dedicados a seguridad (porcentaje de presupuesto TIC, personas equivalentes).
- Correlación entre madurez y frecuencia de incidentes graves, o entre inversión y percepción de ROI.

La guía CCN-STIC 815 propone clasificar las métricas en implantación, eficacia, eficiencia e impacto, esquema que la encuesta respeta.[web:20][web:33] El responsable metodológico puede concretar qué indicadores se utilizarán en cada ejercicio, en función de las prioridades del año.

9. Adaptaciones sectoriales

Aunque la encuesta se ha diseñado para ser sector-agnóstica, es razonable introducir:

- Preguntas específicas sobre regulación sectorial (sanidad, financiero, energía).
- Elementos adicionales de NIS2 (para operadores esenciales e importantes).
- Referencias a marcos sectoriales (Índice SEIS en sanidad, por ejemplo).[web:12]

Estas adaptaciones deben conservar la numeración básica para permitir comparaciones, añadiendo secciones adicionales marcadas como “sectoriales”.

10. Limitaciones y advertencias

Ninguna encuesta reemplaza una auditoría, un análisis de riesgos detallado ni una revisión técnica de vulnerabilidades. Lo que sí ofrece es:

- Una visión panorámica coherente con ENS–INES.
- Una base cuantificable para decisiones estratégicas.
- Un lenguaje común entre seguridad, negocio y órganos de control.

Por el camino, también ayuda a detectar un fenómeno clásico: la distancia entre el discurso oficial sobre la madurez de seguridad y la percepción de quienes están en primera línea.

11. Próximos pasos sugeridos

22. Validar la encuesta con un pequeño grupo piloto dentro de la organización (o conjunto de entidades).
23. Ajustar redacción y ejemplos para maximizar la comprensión.
24. Implementar la captura de respuestas (herramienta de formularios, GRC, etc.).
25. Preparar el modelo de datos para análisis (idealmente exportable a la plantilla de Excel propuesta).
26. Definir el calendario anual de uso de la encuesta en sincronía con INES y ENS.

Si, tras varias iteraciones, el semáforo de madurez sigue en ámbar, la culpa ya no será de la encuesta.